

Intrusion Detection Systems (IDS)

Task 1: Introduction

Task 1  Introduction  

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source [IDS](#) can be combined to provide a per-user breakdown, and scoring of all the [IDS](#) alerts created during the course of a CTF.

You can access the system by navigating to http://MACHINE_IP:8000/register.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at http://MACHINE_IP:8000, in preparation for future tasks.

No answer needed

 Correct Answer

 Hint

Task 2: Intrusion Detection Basics

- Q: What IDS detection methodology relies on rule sets?

A: Signature-based detection

Explanation: Signature-based detection uses predefined attack patterns to detect known threats.

Task 3: Network-based IDS (NIDS)

- Q: What widely implemented protocol has an adverse effect on the reliability of NIDS?

A: TLS

Explanation: TLS encrypts traffic, preventing NIDS from inspecting payload data, reducing detection accuracy.

Task 4: Reconnaissance and Evasion Basics

- Q: What scale is used to measure alert severity in Suricata?

A: 1-3

Explanation: Suricata uses a severity scale from 1 (high) to 3 (low).

- Q: How many services is Nmap able to fully recognize when performing a service scan (-sV)?

A: 3

Explanation: Three services (likely SSH, HTTP, and another) were identified during scanning.

Task 5: Further Reconnaissance Evasion

- Q: What interesting path did Nikto find during the initial scan?

A: /login

Explanation: This represents a login portal, likely linked to Grafana.

- Q: What value toggles denial of service vectors in Nikto (-T)?

A: 6

Explanation: Value '6' enables aggressive scanning/evasion options.

- Q: Which flags modify the request spacing in Nikto?

A: 6,a,b

Explanation: These flags alter Nikto's request timing to reduce NIDS detection.

Task 6: Open-source Intelligence (OSINT)

- Q: What version of Grafana is the server running?

A: 8.2.5

Explanation: Identified through Nmap or manual version check.

- Q: What is the CVE ID affecting this Grafana version?

A: CVE-2021-43798

Explanation: A local file inclusion (LFI) vulnerability in Grafana 8.2.5.

- Q: If publicly available, which site might index this server's services?

A: Shodan

Explanation: Shodan scans and indexes public internet-facing services.

- Q: How do you search for PDF files on example.com using Google?

A: site:example.com filetype:pdf

Explanation: A basic Google Dork syntax for finding file types.

Task 7: Rulesets (Exploitation)

- Q: What is the Grafana admin password?

A: GraphingTheWorld32

Explanation: Retrieved via LFI exploiting Grafana configuration file.

- Q: Can we access the Grafana server directly now (yay/nay)?

A: yay

Explanation: Admin credentials allow successful login to Grafana.

- Q: Which IDS detected access attempts to /etc/shadow?

A: Suricata

Explanation: Suricata detected access to sensitive system files.

Task 8: Host-based IDS (HIDS)

- Q: What category does Wazuh assign to HTTP 400 errors?

A: web

Explanation: Wazuh groups web server errors under its 'web' rule set.

Task 9: Privilege Escalation Recon

- Q: Which tool did LinPEAS identify as a privilege escalation vector?

A: Docker

Explanation: A Docker misconfiguration can allow privilege escalation.

- Q: Did Wazuh trigger an alert for LinPEAS, and what was its severity?

A: Yes, severity 5

Explanation: Wazuh detected LinPEAS as a reconnaissance script with medium severity.

Task 10: Performing Privilege Escalation

- Q: What is the final flag obtained after privilege escalation?

A: {SNEAK_ATTACK_CRITICAL}

Explanation: Flag retrieved from /root/flag.txt after exploiting Docker misconfiguration.

Conclusion

- Q: Summary

A: A layered security approach using Suricata (NIDS) and Wazuh (HIDS) detected both network and host-level activities.

Explanation: The simulation demonstrated real-world detection and evasion scenarios effectively.

Task 8

